

Informe GRC.

El informe GRC de ciberseguridad que planteas, aplicado a España pero con vocación comparada, hoy se escribe —para bien o para susto— con un idioma muy claro: métricas, indicadores y cuadros de mando que ya no se conforman con contar “cuántos incidentes hubo”, sino que pretenden medir madurez sistémica, alineamiento regulatorio y resiliencia socio-técnica a escala país. Voy a estructurar la respuesta en torno a los grandes bloques de GRC (Gobernanza, Riesgo, Cumplimiento), aterrizando en indicadores concretos y en cómo se están viendo en España en el contexto europeo y global desde 2025.¹²

1. Contexto 2025-2026: el nuevo “idioma” de las métricas país

Desde 2025, el debate serio sobre indicadores GRC de ciberseguridad a nivel nacional se ha desplazado desde el recuento de incidentes hacia tres obsesiones: medir madurez, medir criticidad sectorial y medir preparación frente a nuevas tecnologías (nube, 5G, IA, cuántica). ENISA con su marco NIS360, NIST con la extensión de la función “Govern” en el CSF, y los índices industriales (por ejemplo, el Cisco Cybersecurity Readiness Index) son los grandes fabricantes de este idioma común.³⁴⁵⁶

En España, este cambio se injerta sobre una estrategia ya relativamente consolidada: Estrategia Nacional de Ciberseguridad, Plan Nacional de Ciberseguridad, España Digital 2025 y la revisión en marcha hacia 2026, más la adaptación a NIS2, DORA y al “Digital Decade Country Report” de la Comisión. El resultado es que los indicadores GRC “nacionales” ya no se discuten solo en INCIBE o CCN, sino que empiezan a cruzarse con indicadores de política industrial, empleo digital y resiliencia de servicios esenciales.⁷⁸⁹¹⁰

1 https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

2 https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

3 https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

4 https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

5 <https://csrc.nist.gov/projects/risk-management>

6 https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

7 <https://industrialcyber.co/reports/enisas-nis360-report-guides-nis2-directive-implementation-maps-sectoral-maturity-flags-cybersecurity-challenges/>

8 https://administracionelectronica.gob.es/pae_Home/dam/jcr:8292701b-f99d-47f7-a826-9b399dd63987/2025_ficha_informativa_Spain_Decada_digital.pdf

9 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

2. Gobernanza: del “PowerPoint estratégico” al indicador duro

En la dimensión de Gobernanza, la tendencia global desde 2025 es introducir métricas que ya no hablan de buena voluntad, sino de estructuras efectivas y trazables de responsabilidad, supervisión y coordinación interinstitucional. Los marcos de referencia son claros:¹¹¹²

1. NIST Cybersecurity Framework 2.0 incorpora de forma explícita la función “Govern”, que exige mostrar evidencias de gobernanza (políticas, roles, apetito de riesgo, supervisión, métricas de rendimiento y de riesgo).⁹⁴
2. ENISA, a través de NIS2 y NIS360, empuja a los Estados miembros a medir madurez sectorial, criticidad y brecha entre ambas, con indicadores estructurados que permiten comparaciones directas entre países y sectores.²¹
3. La Comisión Europea, con los informes “Digital Decade Country Report 2025”, obliga a los Estados a rendir cuentas sobre capacidades digitales, incluyendo ciberseguridad, como parte de los indicadores de la Década Digital.⁵

En España, estos marcos se traducen en varios tipos de indicadores de gobernanza a nivel nacional:

- Estado de la arquitectura institucional: existencia de un marco legal y organizativo “robusto” y reconocido, con agencias claras (INCIBE, CCN, Mando Conjunto del Ciberespacio, Agencia de Ciberseguridad de referencia).⁸
- Nivel de coordinación y centralización: creación del Centro Nacional de Ciberseguridad adscrito a Presidencia, que busca integrar visión estratégica, inteligencia y coordinación operativa.⁸
- Integración en el marco europeo e internacional: clasificación de España como país TIER 1 en el Global Cybersecurity Index de la UIT y alineamiento con NIS2, DORA y el resto de paquetes digitales de la UE.²⁸

Un ejemplo de cómo estos indicadores se miden en la práctica es la forma en que ENISA presenta las evaluaciones de madurez NIS360: se asigna una puntuación de madurez y una de criticidad a cada sector (energía, banca, salud, telecomunicaciones), y a partir de ahí se define una “zona de riesgo” donde la criticidad nacional supera la madurez de ciberseguridad. Esto no es una simple foto, sino un mapa de gobernanza: indica dónde el Estado tiene la obligación de intensificar supervisión, inversión y coordinación.¹³¹⁴

¹⁰ https://portal.mineco.gob.es/RecursosArticulo/mineco/ministerio/ficheros/210204_Digital_Spain_2025.pdf

¹¹ <https://csrc.nist.gov/projects/risk-management>

¹² <https://industrialcyber.co/reports/enisas-nis360-report-guides-nis2-directive-implementation-maps-sectoral-maturity-flags-cybersecurity-challenges/>

¹³ https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

¹⁴ https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

Tabla: ejemplos de indicadores de gobernanza a nivel país (España vs. enfoque global)

Dimensión	España (ejemplos recientes)	Tendencia global post-2025
Marco institucional	INCIBE, CCN, Mando Conjunto, creación Centro Nacional de Ciberseguridad. ⁸	Consolidación de “National Cybersecurity Centers” como nodo único de coordinación. ¹
Clasificación internacional	TIER 1 en Global Cybersecurity Index UIT. ⁸	Uso de GCI, NIS360 y otros índices para benchmarking entre países. ²
Estrategia nacional	Revisión de Estrategia Nacional de Ciberseguridad integrada en España Digital 2026. ⁸⁷	Estrategias revisadas para incorporar NIS2, IA, cuántica y resiliencia crítica. ¹

La ironía inevitable es que medimos la “buena gobernanza” a golpe de PDF y tabla comparativa, pero la verdadera métrica de gobernanza, por incómodo que resulte, sigue siendo cuántas decisiones difíciles está dispuesto a asumir un gobierno cuando toca cerrar sistemas, sancionar operadores díscolos o invertir donde no da votos.

3. Riesgo: de contar incidentes a modelar madurez y criticidad

En la dimensión de Riesgo, el gran giro desde 2025 es el paso desde indicadores puramente incidentales (número de ataques, tipos, sectores) hacia indicadores que combinan probabilidad, impacto y madurez de control, muchas veces con un enfoque “actuarial” todavía en pañales pero cada vez más explícito.

ENISA NIS360 ejemplifica esta tendencia: el informe evalúa los sectores cubiertos por NIS2 en dos ejes—criticidad (importancia para el funcionamiento de la sociedad y la economía) y madurez de ciberseguridad (nivel de capacidades, controles, gobernanza)—y define una “risk zone” cuando la criticidad supera la madurez. Sectores como la gestión de servicios TIC, ciertos servicios digitales y algunos segmentos industriales aparecen repetidamente en esta zona, lo que implica una priorización política y presupuestaria inmediata.¹⁵¹⁶

España, como Estado miembro, no aparece aislada, sino integrada en estas métricas europeas: sus operadores esenciales y entidades importantes deberán alinearse con NIS2 y, por extensión, sus indicadores de riesgo se harán visibles a través de este tipo de mecanismos. Además, el propio Gobierno reconoce el crecimiento sostenido de los ataques: un aumento del 300% desde 2015 y más de 100.000 ciberataques en 2024, con un incidente “muy grave” cada tres días, lo que sirve de indicador bruto pero contundente del riesgo agregado país.¹⁷¹⁸¹⁹

¹⁵ https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

¹⁶ https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

¹⁷ https://administracionelectronica.gob.es/pae_Home/dam/jcr:8292701b-f99d-47f7-a826-9b399dd63987/2025_ficha_informativa_Spain_Decada_digital.pdf

A nivel industrial, informes como el Cisco Cybersecurity Readiness Index 2025 introducen otro tipo de métrica relevante para el riesgo nacional: el porcentaje de organizaciones en cada nivel de preparación (Beginner, Formative, Progressive, Mature) en dominios como identidad, puntos finales, redes, aplicaciones y datos. En el caso de España, el informe señala un retroceso en la resiliencia de red, con un desplazamiento desde categorías más maduras hacia niveles formativos, lo que sugiere que, pese a los avances estratégicos, ciertas capacidades técnicas sufren por complejidad, deuda técnica o falta de talento.²⁰

La lectura actuarial de todo esto es clara: los Estados empiezan a disponer de suficientes indicadores para construir funciones de pérdida esperada, escenarios de estrés y curvas de decaimiento de madurez si no se invierte de forma sostenida. La parte que todavía da pudor reconocer es que, a día de hoy, la mayoría de los modelos nacionales siguen siendo más un conjunto de proxies estadísticos que una auténtica modelización de riesgo al estilo de los seguros o la banca.

Tabla: indicadores de riesgo clave en 2025–2026

Tipo de indicador	España	Enfoque
internacional		
Incidentes	+100.000 ataques en 2024, un incidente muy grave cada tres días. ²¹	
Uso de estadísticas de CERTs y CSIRTs nacionales como base mínima de riesgo.		
Madurez vs. criticidad	Sectores españoles evaluados en el marco NIS2 y NIS360 (mapeo UE). ^{22,23}	
ENISA NIS360 define la “risk zone” a nivel UE. ²⁴		
Preparación organizacional	Empresas españolas evaluadas en el Cisco Readiness Index con deterioro en resiliencia de red. ²⁵	Índices industriales globales para comparar preparación sectorial y por país. ²⁶

¹⁸ https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

¹⁹ https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

²⁰ https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

²¹ https://administracionelectronica.gob.es/pae_Home/dam/jcr:8292701b-f99d-47f7-a826-9b399dd63987/2025_ficha_informativa_Spain_Decada_digital.pdf

²² https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

²³ https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

²⁴ https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

²⁵ https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

²⁶ https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

4. Cumplimiento: NIS2, DORA y la metricocracia regulatoria

En el campo del Cumplimiento, el periodo 2025–2026 está dominado por dos grandes fuerzas: la implementación de NIS2 y DORA en la UE, y la evolución de marcos como NIST RMF y CSF en el mundo anglosajón. Ambas corrientes convergen en algo que los viejos GRC ya intuían: el cumplimiento no es un fin, sino una fuente de indicadores, y si no se miden bien, todo el sistema regulatorio se queda en un ejercicio litúrgico.

NIS2 impone a los Estados miembros la obligación de supervisar y hacer cumplir requisitos de gestión de riesgos de ciberseguridad, notificación de incidentes y gobernanza de alto nivel (incluyendo responsabilidad de la dirección). ENISA, a través de NIS360, proporciona una plantilla de indicadores que los Estados pueden usar para monitorizar el grado de cumplimiento sectorial y la efectividad de las medidas, lo que incluye:²⁷²⁸

- Porcentaje de entidades esenciales con planes de gestión de riesgos verificados.
- Tiempos de notificación de incidentes críticos.
- Nivel de implantación de controles técnicos claves (segmentación, gestión de identidades, registro y monitorización).¹²

España está en pleno proceso de refuerzo regulatorio: el Gobierno ha aprobado medidas adicionales de ciberseguridad y ciberdefensa, vinculadas al Plan Nacional de Ciberseguridad y a un paquete de inversión de más de 1.157 millones de euros, con énfasis en la mejora de la protección de infraestructuras críticas y sistemas públicos. Además, España Digital 2025 fija objetivos cuantificados de digitalización de administraciones públicas (50% de servicios públicos digitalizados) y de formación de nuevos especialistas en ciberseguridad, IA y datos (20.000 nuevos profesionales), que funcionan como indicadores de capacidad futura de cumplimiento.²⁹³⁰

En paralelo, NIST actualiza su catálogo de controles SP 800-53 (versión 5.2.0 en 2025) para reforzar requisitos de actualización segura y confiable, gestión de parches y otros controles que influyen directamente en indicadores de cumplimiento técnico. La Risk Management Framework (SP 800-37) sigue proponiendo un ciclo continuo de preparar, categorizar, seleccionar, implementar, evaluar, autorizar y monitorizar, que se traduce en métricas de ciclo de vida y estado de control.³¹³²

²⁷ https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

²⁸ https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

²⁹ https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

³⁰ <https://csrc.nist.gov/projects/risk-management>

³¹ <https://csrc.nist.gov/projects/risk-management>

³² <https://csrc.nist.gov/projects/risk-management>

La moraleja para cualquier consorcio de CISOs y arquitectos Zero Trust con aspiraciones cuánticas es que el cumplimiento se ha convertido en una máquina de generar métricas: si se diseña bien, produce indicadores que informan el riesgo y la gobernanza; si se diseña mal, produce hojas de cálculo y migrañas.

Tabla: ejemplos de indicadores de cumplimiento

Marco	Indicador típico	Aplicación en España / UE
NIS2 / NIS360	Porcentaje de entidades con gestión de riesgos alineada a NIS2.12	Supervisión sectorial por autoridades nacionales, coordinación con ENISA.1
NIS2	Tiempo medio de notificación de incidentes a CSIRT nacional.1	Integración con INCIBE-CERT y CCN-CERT para sectores públicos y privados.6
España Digital 2025	Nº de especialistas en ciberseguridad formados; digitalización de servicios públicos.7	Indicador de capacidad de cumplimiento y de resiliencia institucional.7
NIST RMF / SP 800-53	Porcentaje de controles implementados y evaluados satisfactoriamente.4	Uso como referencia por organizaciones multinacionales y sectores regulados.

5. Aplicación nacional en España y mirada comparada

Si tuviéramos que sintetizar el “cuadro de mando” GRC nacional de España con perspectiva global, a partir de las tendencias desde 2025, podríamos imaginar algo así:

En Gobernanza, España presenta un marco institucional robusto, reconocido internacionalmente y categorizado como TIER 1 en el índice global de ciberseguridad de la UIT, con un entramado de organismos especializados y la reciente creación de un Centro Nacional de Ciberseguridad bajo Presidencia para reforzar la coordinación y la capacidad estratégica. Comparativamente, esto sitúa a España en el grupo de países que ya no discuten si necesitan gobernanza centralizada, sino cómo hacerla más efectiva y menos fragmentada, algo que también reflejan las mejores prácticas promovidas por ENISA para los Estados miembros.³³³⁴³⁵

En Riesgo, los datos de incidentes muestran un entorno crecientemente hostil (300% de incremento en ataques desde 2015, más de 100.000 en 2024), acompañado de una transición europea hacia métricas de madurez y criticidad que obligan a España a mirar no solo cuántos ataques sufre, sino en qué sectores la brecha entre importancia y preparación es más peligrosa. Los informes industriales apuntan que, pese a

33 https://administracionelectronica.gob.es/pae_Home/dam/jcr:8292701b-f99d-47f7-a826-9b399dd63987/2025_ficha_informativa_Spain_Decada_digital.pdf

34 https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

35 https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

una infraestructura digital avanzada, ciertas capacidades (como la resiliencia de red empresarial) muestran signos de fatiga o retroceso, lo que la alinea con una tendencia mundial donde la complejidad tecnológica corre más rápido que la capacidad de gestión.³⁶³⁷³⁸³⁹⁴⁰⁴¹

En Cumplimiento, la combinación de NIS2, DORA, las iniciativas de la Década Digital y España Digital 2025 empuja a una metricocracia regulatoria donde cada obligación legal acaba traducándose en un indicador: desde el porcentaje de operadores esenciales con planes de ciberseguridad auditados hasta el nivel de competencias digitales de empleados públicos y privados. En comparación internacional, España se mueve en línea con otros Estados de la UE que han optado por marcos de cumplimiento densos pero relativamente coherentes, frente a otros entornos donde coexisten marcos sectoriales dispares sin una narrativa común.⁴²⁴³⁴⁴⁴⁵

El reto que queda —para tu consorcio de CISOs, criptógrafos y estrategas— es menos técnico y más político: transformar este conjunto exuberante de indicadores GRC en un sistema que permita tomar decisiones difíciles con claridad y anticipación. O dicho de otra forma: conseguir que la métrica no sea un fin en sí misma, sino una brújula que señale dónde invertir, dónde regular con más uñas y dónde aceptar, con serenidad poco marketiniana, que cierto nivel de riesgo residual es parte del trato.

1112131415

36 https://administracionelectronica.gob.es/pae_Home/dam/jcr:8292701b-f99d-47f7-a826-9b399dd63987/2025_ficha_informativa_Spain_Decada_digital.pdf

37 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

38 https://digital.gob.es/en/comunicacion/notas-prensa/mtdfp/2025/05/2025-05-06_02

39 <https://industrialcyber.co/reports/enisas-nis360-report-guides-nis2-directive-implementation-maps-sectoral-maturity-flags-cybersecurity-challenges/>

40 https://newsroom.cisco.com/c/dam/r/newsroom/en/us/interactive/cybersecurity-readiness-index/2025/documents/2025_Cisco_Cybersecurity_Readiness_Index_ES.pdf

41 https://www.enisa.europa.eu/sites/default/files/2025-03/ENISA - NIS360 - 2024_0.pdf

42 https://portal.mineco.gob.es/RecursosArticulo/mineco/ministerio/ficheros/210204_Digital_Spain_2025.pdf

43 <https://industrialcyber.co/reports/enisas-nis360-report-guides-nis2-directive-implementation-maps-sectoral-maturity-flags-cybersecurity-challenges/>

44 <https://www.lamoncloa.gob.es/lang/en/presidente/news/paginas/2025/20251016-information-security-meeting.aspx>

45 <https://www.thoropass.com/blog/about-nist-800-37-compliance-in-2025>